

CVE-2026-0257

Palo Alto Networks PAN-OS GlobalProtect Authentication Bypass

Lost Boys Cyber / RAlccoon Vulnerability Intelligence Report

Prepared For	Lost Boys Cyber / RAlccoon Reports
Prepared By	RAlccoon Analyst
Date	2026-06-01
TLP	TLP:AMBER
Disposition	Active exploitation / immediate remediation

Report Type: Vulnerability Intelligence / Active Exploitation Report

Subject: Palo Alto Networks PAN-OS GlobalProtect Authentication Bypass

Prepared For: Lost Boys Cyber / RALccoon Reports

Prepared By: RALccoon Analyst

Date: 2026-06-01

TLP: TLP:AMBER

AI Disclosure: This report was drafted with AI assistance and manually structured using public-source vulnerability intelligence. Source claims were cross-checked against vendor, NVD/CISA, Rapid7, and public repository evidence available on 2026-06-01.

Executive Summary

CVE-2026-0257 is an authentication bypass vulnerability affecting Palo Alto Networks PAN-OS GlobalProtect portal and gateway deployments when authentication override cookies are enabled and certificate reuse creates a vulnerable trust relationship. Successful exploitation allows a remote unauthenticated attacker to establish an unauthorized VPN connection through an affected GlobalProtect deployment.

Palo Alto Networks published the advisory on 2026-05-13 and updated it on 2026-05-29 after becoming aware of limited exploit attempts. NVD lists the flaw as CVSS 3.1 9.1 critical, while Palo Alto's CVSS 4.0 score is 7.8 high. CISA added CVE-2026-0257 to the Known Exploited Vulnerabilities catalog on 2026-05-29 with a federal due date of 2026-06-01. Rapid7 reported successful exploitation across multiple MDR customer environments beginning 2026-05-17, including cases where attackers received VPN IP assignment.

RALccoon assesses this vulnerability as **critical operational priority** despite the vendor CVSS 4.0 high rating. The exposed component is an edge-facing VPN control plane, exploitation is unauthenticated, public proof-of-concept code is available, and the impact can place an attacker directly inside the defended network boundary.

Vulnerability Metadata

Field	Detail
CVE	CVE-2026-0257
Vendor	Palo Alto Networks
Product	PAN-OS GlobalProtect portal and gateway; Prisma Access versions listed by vendor
Vulnerability Class	Authentication bypass / cookie trust failure
CWE	CWE-565: Reliance on Cookies without Validation and Integrity Checking
CAPEC	CAPEC-114: Authentication Abuse
Initial Publication	2026-05-13
Vendor Update	2026-05-29
Exploitation Status	Active exploitation reported
CISA KEV	Added 2026-05-29; due 2026-06-01
Palo Alto CVSS 4.0	7.8 High
NVD CVSS 3.1	9.1 Critical
Attack Vector	Network

Field	Detail
Privileges Required	None
User Interaction	None
Primary Impact	Unauthorized VPN access and potential internal network entry

Source Review & Confidence

Source	Evidence Used	Confidence
Palo Alto Networks advisory	Affected versions, required vulnerable configuration, mitigation, exploit maturity, CVSS 4.0, CWE/CAPEC	High
NVD	CVE metadata, NVD CVSS 3.1, CISA KEV status and required action	High
CISA KEV via NVD enrichment	Known exploited status, federal mitigation deadline	High
Rapid7 exploitation report	Observed exploitation timeline, attacker behavior, log patterns, IoCs, technical root cause analysis	High
Rapid7 public PoC repository	Public exploit validation availability and high-level exploit workflow	Medium-High

Evidence gap: Palo Alto's advisory confirms limited exploitation but does not publish detailed IoCs. Rapid7 provides the most detailed attacker behavior and IoC set. No private telemetry was available during this report build.

Vulnerability Details

GlobalProtect authentication override is a feature that allows the portal or gateway to issue an authentication cookie after a valid login. That cookie can later be presented in place of credentials. The feature is not enabled by default, but it is common enough in enterprise VPN deployments to matter operationally.

The vulnerable condition requires both:

1. GlobalProtect portal or gateway configured with authentication override cookies enabled.
2. Authentication override cookie certificate reuse or exposure in a way that lets an attacker derive the public key needed to forge a cookie accepted by the appliance.

Rapid7's technical analysis describes the authentication override cookie as encrypted data that is decrypted by the GlobalProtect service and then trusted without a separate integrity/signature verification step. If the public key used for cookie encryption is discoverable through the HTTPS certificate chain, an unauthenticated attacker can forge an authentication override cookie for an arbitrary user, submit it to GlobalProtect, and potentially receive a valid VPN session.

The attack does not require credentials, user interaction, or prior network position. The practical risk is highest for internet-exposed GlobalProtect portals and gateways where authentication override is enabled and the certificate configuration matches the vulnerable pattern.

Affected Products and Exposure

Palo Alto Networks lists the following affected and fixed branches:

Product / Branch	Affected Versions	Fixed / Unaffected Versions
PAN-OS 12.1	< 12.1.4-h6, < 12.1.7	>= 12.1.4-h6, >= 12.1.7
PAN-OS 11.2	< 11.2.4-h17, < 11.2.7-h14, < 11.2.10-h7, < 11.2.12	>= 11.2.4-h17, >= 11.2.7-h14, >= 11.2.10-h7, >= 11.2.12
PAN-OS 11.1	< 11.1.4-h33, < 11.1.6-h32, < 11.1.7-h6, < 11.1.10-h25, < 11.1.13-h5, < 11.1.15	>= 11.1.4-h33, >= 11.1.6-h32, >= 11.1.7-h6, >= 11.1.10-h25, >= 11.1.13-h5, >= 11.1.15
PAN-OS 10.2	< 10.2.7-h34, < 10.2.10-h36, < 10.2.13-h21, < 10.2.16-h7, < 10.2.18-h6	>= 10.2.7-h34, >= 10.2.10-h36, >= 10.2.13-h21, >= 10.2.16-h7, >= 10.2.18-h6
Prisma Access 11.2.0	< 11.2.7-h13	>= 11.2.7-h13
Prisma Access 10.2.0	< 10.2.10-h36	>= 10.2.10-h36

Palo Alto states Panorama and Cloud NGFW are not impacted.

Attack Scenarios

Scenario 1: Forged Cookie to Unauthorized VPN Session

An attacker identifies an internet-facing GlobalProtect portal or gateway. The attacker retrieves the TLS certificate chain and attempts to use exposed public keys to construct authentication override cookies. If the appliance accepts the forged cookie, the attacker authenticates as a selected account and may receive a VPN IP address.

Likely outcomes:

- VPN authentication event using method Cookie
- Local or privileged account name such as admin
- Hostname and MAC values that do not match known managed endpoints
- VPN address assignment in successful cases
- Follow-on internal discovery, credential access, or lateral movement attempts

Scenario 2: Authentication Probing Without VPN Assignment

Rapid7 observed forged cookie authentication probes across multiple customers where the cookie was accepted but full VPN session establishment was not always observed. This still indicates successful authentication bypass and should be handled as compromise of the VPN authentication boundary.

Likely outcomes:

- GlobalProtect gateway-auth login success with Cookie
- Repeated testing against portal and gateway contexts
- Source IPs from low-cost hosting providers
- No immediate endpoint telemetry if the attacker does not receive or use tunnel access

Threat Landscape & Exploitation Status

Palo Alto Networks changed exploit maturity to ATTACKED and confirmed limited exploit attempts against unpatched, unmitigated PAN-OS devices. Rapid7 observed successful exploitation beginning 2026-05-17, with a second wave on 2026-05-21. Rapid7 linked both waves by a repeated spoofed MAC address and reported source infrastructure from Vultr and

Dromatics Systems.

Public exploitation risk increased after release of Rapid7's proof-of-concept validation script. The PoC is framed as an exposure test, but the same mechanics demonstrate the exploit path: retrieve certificate chain, forge authentication override cookies, and test whether the GlobalProtect portal or gateway accepts them.

RAIcco0n likelihood assessment:

Factor	Assessment
Internet-facing attack surface	High
Exploit complexity	Low once vulnerable configuration is present
Public exploit availability	Confirmed
Active exploitation	Confirmed
Attacker value	High due to VPN perimeter access
Near-term exploitation pressure	High

Known Indicators

Rapid7 published the following indicators associated with observed exploitation:

Indicator	Type	Notes
104.207.144.154	Source IP	Threat actor source IP observed by Rapid7
146.19.216.119	Source IP	Threat actor source IP observed by Rapid7
146.19.216.120	Source IP	Threat actor source IP observed by Rapid7
146.19.216.125	Source IP	Threat actor source IP observed by Rapid7
DESKTOP-GP01	Hostname	Windows hostname observed in GlobalProtect logs
GP-CLIENT	Hostname	Linux hostname observed in GlobalProtect logs
aa:bb:cc:dd:ee:ff	MAC address	Spoofed MAC address observed in both Rapid7 exploitation waves

Treat these as retrospective hunt seeds, not complete blocklists. Absence of these indicators does not rule out exploitation.

Mitigation and Workarounds

Priority actions:

1. Upgrade PAN-OS and Prisma Access to fixed versions listed by Palo Alto Networks.
2. Disable GlobalProtect authentication override where operationally possible.
3. If authentication override is required, generate a dedicated certificate used only for authentication override cookies.
4. Do not reuse portal or gateway HTTPS certificates for authentication override cookies.

5. Force reauthentication after patching and review all recent cookie-based GlobalProtect authentications.
6. Inspect local administrator and privileged account use through GlobalProtect.
7. Review VPN address assignments and internal access from suspicious GlobalProtect sessions since at least 2026-05-13; prioritize 2026-05-17 onward.

Operational note: Palo Alto states the fix regenerates authentication override cookies using a more secure method, causing GlobalProtect users to reauthenticate once after upgrade.

Detection Engineering

Sigma: Suspicious GlobalProtect Cookie Authentication to Privileged or Generic Account

```

title: Suspicious Palo Alto GlobalProtect Cookie Authentication
id: 2f5b9f5b-7c15-4f4c-92cb-cve20260257
status: experimental
description: Detects GlobalProtect cookie-based authentication to privileged or generic
accounts, consistent with CVE-2026-0257 exploitation patterns.
references:
  - https://security.paloaltonetworks.com/CVE-2026-0257
  - https://www.rapid7.com/blog/post/etr-rapid7-observed-exploitation-of-pan-os-
globalprotect-authentication-bypass-vulnerability-cve-2026-0257/
logsource:
  product: paloalto
  service: globalprotect
detection:
  selection:
    event_type|contains: 'gateway-auth'
    action|contains: 'login'
    auth_method|contains: 'Cookie'
    result|contains: 'success'
  privileged_user:
    user|re: '(?i)^(admin|administrator|root|vpnadmin|localadmin)$'
  known_iocs:
    src_ip:
      - '104.207.144.154'
      - '146.19.216.119'
      - '146.19.216.120'
      - '146.19.216.125'
  suspicious_client:
    client_hostname:
      - 'DESKTOP-GP01'
      - 'GP-CLIENT'
    client_mac: 'aa:bb:cc:dd:ee:ff'
  condition: selection and (privileged_user or known_iocs or suspicious_client)
fields:
  - src_ip
  - user
  - client_hostname
  - client_mac
  - auth_method
  - gateway
falsepositives:
  - Legitimate authentication override use by managed endpoints with expected hostnames and
MAC addresses.
level: high

```

Splunk SPL: Cookie Auth Success From Suspicious Host or MAC

```

index=pan_logs (sourcetype=pan:globalprotect OR sourcetype=pan:system OR sourcetype=pan:
threat)
("GLOBALPROTECT" OR subtype="globalprotect")
("gateway-auth" OR eventid="gateway-auth")
("Cookie" AND "success")
| eval user_l=lower(coalesce(user,src_user,duser))
| eval host=coalesce(hostname,machine_name,client_hostname)
| eval mac=lower(coalesce(src_mac,client_mac,mac_address))
| search user_l IN ("admin","administrator","root","vpnadmin","localadmin")
OR src_ip IN ("104.207.144.154","146.19.216.119","146.19.216.120","146.19.216.125")
OR host IN ("DESKTOP-GP01","GP-CLIENT")
OR mac="aa:bb:cc:dd:ee:ff"
| table _time host src_ip user_l mac auth_method gateway eventid action result assigned_ip

```

Microsoft Sentinel KQL: GlobalProtect Cookie Authentication Hunt

```

let SuspiciousIPs = dynamic(["104.207.144.154", "146.19.216.119", "146.19.216.120", "146.19.216.125"]);
let SuspiciousHosts = dynamic(["DESKTOP-GP01", "GP-CLIENT"]);
CommonSecurityLog
| where DeviceVendor has_any ("Palo Alto", "Palo Alto Networks")
| where DeviceProduct has_any ("PAN-OS", "GlobalProtect")
| where Activity has_any ("gateway-auth", "login") or DeviceEventClassID has "gateway-auth"
| where Message has "Cookie" and Message has "success"
| extend UserLower = tolower(coalesce(SourceUserName, DestinationUserName, RequestClientApplication))
| extend ClientHost = toString(coalesce(DeviceCustomString1, DeviceCustomString2, Computer))
| extend ClientMac = tolower(tostring(coalesce(SourceMACAddress, DeviceCustomString3)))
| where SourceIP in (SuspiciousIPs)
    or ClientHost in (SuspiciousHosts)
    or ClientMac == "aa:bb:cc:dd:ee:ff"
    or UserLower in ("admin", "administrator", "root", "vpnadmin", "localadmin")
| project TimeGenerated, DeviceName, SourceIP, UserLower, ClientHost, ClientMac, Activity, Message

```

Palo Alto Log Review CLI Concepts

Use the management interface or log export tooling to review GlobalProtect authentication logs for:

- auth_method=Cookie
- eventid=gateway-auth
- user=admin or other local privileged users
- suspicious hostnames DESKTOP-GP01 or GP-CLIENT
- suspicious MAC aa:bb:cc:dd:ee:ff
- unexpected source ASNs or low-cost hosting providers
- successful cookie authentication followed by VPN IP assignment

Threat Hunting

Recommended hunt window: 2026-05-13 through present, with heightened focus on 2026-05-17, 2026-05-18, 2026-05-21, and 2026-05-29 onward.

Hunt questions:

1. Which GlobalProtect authentications used Cookie rather than credentials, SAML, or certificate authentication?
2. Did any cookie-based authentication target local accounts, shared accounts, or privileged accounts?
3. Were any cookie-authenticated sessions assigned VPN IP addresses?
4. Did any cookie-authenticated sessions originate from hosting/VPS providers?
5. Do hostnames, client OS strings, MAC addresses, or GlobalProtect client versions match managed device inventory?
6. After suspicious VPN access, did the source access internal identity, file share, admin, EDR, or cloud connector systems?

Follow-on telemetry to correlate:

- VPN session start and end logs
- DHCP/VPN address assignment logs
- Firewall traffic logs from assigned VPN IPs
- Identity provider logs for absence of corresponding successful login
- Endpoint detections tied to internal destinations reached by suspicious VPN sessions
- Administrative configuration changes on the firewall

MITRE ATT&CK Mapping

Technique	Name	Relevance
T1190	Exploit Public-Facing Application	Exploitation targets internet-facing GlobalProtect portals/gateways
T1133	External Remote Services	Successful exploitation may establish VPN access
T1078	Valid Accounts	Forged cookie can impersonate local or privileged account context
T1550.004	Use Alternate Authentication Material: Web Session Cookie	Attack abuses authentication override cookie trust
T1021	Remote Services	Follow-on lateral movement may use VPN-reachable internal services
T1046	Network Service Discovery	Likely post-VPN reconnaissance behavior

Validation / Lab Testing

No live exploitation was performed for this report. Public Rapid7 proof-of-concept code exists and should only be used against assets an organization owns or is explicitly authorized to test. A safe validation approach is:

1. Inventory all internet-facing GlobalProtect portals and gateways.
2. Confirm PAN-OS version and GlobalProtect authentication override configuration via authenticated administrative review.
3. Confirm whether the authentication override certificate is dedicated and not reused by HTTPS or other services.
4. If using an exposure scanner or PoC, restrict testing to owned appliances and approved maintenance windows.
5. Preserve pre- and post-test GlobalProtect authentication logs for detection validation.

Recommended Actions Summary

Priority	Action	Owner
Immediate	Patch PAN-OS/Prisma Access to vendor fixed versions	Network / Firewall Engineering
Immediate	Disable authentication override if not strictly required	Network / IAM
Immediate	Replace reused authentication override certificates with dedicated certificates	PKI / Firewall Engineering
Immediate	Hunt GlobalProtect cookie authentications since 2026-05-13	SOC / Threat Hunting
24 Hours	Review suspicious VPN sessions for internal access and lateral movement	IR / SOC
72 Hours	Add detections for cookie auth to privileged accounts, suspicious MAC/hostnames, and hosting-provider sources	Detection Engineering

Priority	Action	Owner
7 Days	Validate GlobalProtect hardening baseline across all edge appliances	Security Architecture

Analyst Assessment

CVE-2026-0257 should be treated as an actively exploited perimeter access vulnerability. The technical issue is narrower than a universal PAN-OS authentication bypass because it depends on authentication override and certificate configuration. In practice, that configuration nuance should not reduce response urgency: exposed GlobalProtect infrastructure is a high-value target, the exploit path is public, and successful exploitation can grant internal network access without valid credentials.

Organizations should prioritize patching and configuration remediation first, then hunt for cookie-authenticated VPN sessions that bypassed expected identity-provider telemetry. Any suspicious cookie-based login to a local administrator account or unmanaged endpoint identity should be escalated as a potential intrusion, even if lateral movement is not immediately visible.

References

1. Palo Alto Networks Security Advisory, CVE-2026-0257: <https://security.paloaltonetworks.com/CVE-2026-0257>
2. NVD, CVE-2026-0257: <https://nvd.nist.gov/vuln/detail/CVE-2026-0257>
3. CISA Known Exploited Vulnerabilities Catalog, CVE-2026-0257 filter: https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-0257
4. Rapid7, Observed Exploitation of PAN-OS GlobalProtect Authentication Bypass Vulnerability: <https://www.rapid7.com/blog/post/etr-rapid7-observed-exploitation-of-pan-os-globalprotect-authentication-bypass-vulnerability-cve-2026-0257/>
5. Rapid7 PoC Repository by Stephen Fewer: <https://github.com/sfewer-r7/CVE-2026-0257>
6. MITRE CWE-565: <https://cwe.mitre.org/data/definitions/565.html>
7. MITRE CAPEC-114: <https://capec.mitre.org/data/definitions/114.html>